

高度脅威ハンティング 拡張チートシート

MUST-HAVE: 見逃し厳禁の高度な攻撃アーティファクトとクエリ集

本ドキュメントは、標準的なキルチェーン監視（前版）に加え、Webシェル、WMIの悪用、正規プロセスのハイジャック、ランサムウェアの準備行動など、「現代のSOCにおいて確実に検知しておくべき高度な攻撃手法」を網羅した拡張リファレンスです。

1. 偵察 (Reconnaissance) 拡張

1-1. 不審なUser-Agentによる自動化ツールのスキャン検知

Nmap、Nikto、Pythonスクリプトなど、攻撃者が自動化ツールを用いてWeb脆弱性を探索する際の特有のヘッダーを検知します。

Zeek

Proxy/Web

```
# HTTPリクエストのUser-Agentにスキャナー固有の文字列が含まれるものを抽出

index=zeek sourcetype=zeek_http
(user_agent="*nmap*" OR user_agent="*python-requests*" OR
user_agent="*curl/*" OR user_agent="*nikto*")
| stats count, dc(uri) as unique_uris by src_ip, user_agent,
dest_ip
| sort - count
```

3. 配送 (Delivery) 拡張

3-1. 新規取得ドメイン (NRD) からのダウンロードとアクセス

攻撃者は使い捨てのドメイン（作成されてから数日以内）を利用してペイロードを配信します。プロキシログと脅威インテリジェンスの連携が不可欠です。

Proxy/Web

Zeek

```
# Web/Proxyログからドメインを抽出し、ルックアップで新規取得（30日以内）判定を行う想定ロジック

index=proxy OR index=zeek sourcetype=zeek_http
| lookup domain_age_intel domain AS dest_host OUTPUT
is_newly_registered
| where is_newly_registered="true" AND (action="allowed" OR
status_code=200)
| stats count by src_ip, dest_host, uri_path
```

3-2. 不正なUSB・リムーバブルメディアの接続検知

オフライン環境や物理的な侵入によるペイロード配送を検知します。

Sysmon

Windows

PnP (Plug and Play) イベントによるUSB接続の検知

```
(index=sysmon EventCode=20) OR (index=wineventlog EventCode=2003  
OR EventCode=2004 SourceName="Microsoft-Windows-Kernel-PnP")  
| stats count by host, DeviceName, Vendor, SerialNumber, _time
```

4. エクスプロイト (Exploitation) 拡張 - ★超重要

4-1. Webシェルの実行検知 (Webサーバーからの不審プロセス生成)

IISやApache、TomcatなどのWebサーバープロセスが、直接 `cmd.exe` や `powershell.exe` を生成する挙動は、Webシェルを通じたりモートコード実行(RCE)の確実な証拠です。

Sysmon

プロセス監視

Webサービスプロセスがシェルやスクリプトエンジンの子プロセスとして起動した事象

```
index=sysmon EventCode=1  
(ParentImage="*\\w3wp.exe" OR ParentImage="*\\nginx.exe" OR  
ParentImage="*\\httpd.exe" OR ParentImage="*\\tomcat*.exe")  
(Image="*\\cmd.exe" OR Image="*\\powershell.exe" OR Image="*\\  
sh.exe" OR Image="*\\bash.exe")  
| stats count by host, ParentImage, Image, CommandLine, User
```

4-2. Officeアプリケーションからの不審な子プロセス

WordやExcelのマクロ、または脆弱性を突かれてスクリプトが実行される挙動を検知します。

Sysmon

Officeアプリがシステムコマンドを呼び出す異常挙動

```
index=sysmon EventCode=1  
(ParentImage="*\\WINWORD.EXE" OR ParentImage="*\\EXCEL.EXE" OR  
ParentImage="*\\POWERPNT.EXE")  
(Image="*\\cmd.exe" OR Image="*\\powershell.exe" OR Image="*\\  
wscript.exe" OR Image="*\\cscript.exe" OR Image="*\\mshta.exe")  
| stats count by host, ParentImage, Image, CommandLine
```

5. インストール (Installation / Persistence) 拡張

5-1. WMI イベントサブスクリプションによるステルス永続化

ファイルやレジストリを使わず、WMI (Windows Management Instrumentation) 内に悪意のあるスクリプトを潜ませる高度な永続化手法 (ファイルレスマルウェア) を検知します。

Sysmon
WMI監視

```
# Sysmon EID 19, 20, 21によるWMIアクティビティ（フィルタとコンシューマーのバインド）

index=sysmon (EventCode=19 OR EventCode=20 OR EventCode=21)
| stats count by host, EventCode, Operation, User, Destination, Consumer
```

5-2. 新規のWindowsサービス作成

システム権限(SYSTEM)でマルウェアを自動起動させるため、攻撃者はよく新規サービスを登録します。

Windows

```
# セキュリティログ EventCode 7045（サービスの新規インストール）

index=wineventlog EventCode=7045
| stats count by host, ServiceName, ServiceType, ImagePath, SubjectUserName
```

6. 遠隔操作 (C2) 拡張

6-1. 長時間継続する不審なTCPセッション

ビーコニングのような断続的な通信ではなく、リバースシェル等で維持され続ける「長寿命」のセッションを炙り出します。

Zeek

```
# Zeekのconn.logで、接続期間(duration)が極端に長い（例：24時間以上）内部から外部への通信

index=zeek sourcetype=zeek_conn duration > 86400 (src_ip=10.* OR src_ip=192.168.* OR src_ip=172.16.*)
NOT (dest_ip=10.* OR dest_ip=192.168.* OR dest_ip=172.16.*)
| stats count by src_ip, dest_ip, dest_port, duration, orig_bytes
```

6-2. 大量のNXDOMAIN (DGA: ドメイン生成アルゴリズムの疑い)

マルウェアがランダムなドメインを大量に生成してC2サーバーを探す挙動（名前解決の失敗の連続）を検知します。

Zeek
DNS

```
# RCODE=3 (NXDOMAIN: 存在しないドメイン) の割合が異常に高いソースIPを特定

index=zeek sourcetype=zeek_dns rcode_name="NXDOMAIN"
| bucket _time span=10m
| stats count as nxdomain_count, dc(query) as unique_queries by src_ip, _time
| where nxdomain_count > 100 AND unique_queries > 50
```

7. 目的の実行 (Actions on Objectives) 拡張 - ★重大インシデント直前

7-1. ボリュームシャドウコピー (VSS) の削除 (ランサムウェア準備)

ランサムウェアは、システム復元を防ぐために暗号化の直前に必ずVSSバックアップを削除します。このログは即時対応必須 (Critical) のアラートとして扱います。

Sysmon コマンド監視

```
# vssadmin, wmic, bcdedit を用いた復元領域の削除・無効化コマンド

index=sysmon EventCode=1
(CommandLine="*vssadmin* delete shadows*" OR CommandLine="*wmic*
shadowcopy delete*" OR CommandLine="*bcdedit* /set {default}
recoveryenabled No*")
| stats count by host, User, Image, CommandLine, _time
```

7-2. イベントログの意図的な消去 (隠蔽工作)

攻撃者が自らの痕跡を消すためにセキュリティログを消去した証拠です。

Windows

```
# EventCode 1102 (監査ログの消去) または Sysmon EventCode 104 (ログクリ
ア)

(index=wineventlog EventCode=1102) OR (index=sysmon
EventCode=104)
| stats count by host, SubjectUserName, LogFile_Cleared, _time
```

7-3. データ持ち出しに向けたステージング (機密データの圧縮)

データ持ち出し (Exfiltration) の前に、攻撃者はサーバー内でデータをパスワード付きZIPやRARで一つのファイルにまとめます。

Sysmon

```
# 圧縮ツール(7z.exe, rar.exe)にパスワード付与や隠しオプション(-p, -hp)をつけて
実行した形跡

index=sysmon EventCode=1
(Image="*\\7z.exe" OR Image="*\\rar.exe" OR Image="*\\
WinRAR.exe")
(CommandLine="*-p*" OR CommandLine="*-hp*" OR CommandLine="*-
mhe*")
| stats count by host, User, CommandLine, CurrentDirectory
```